

BÁO CÁO THỰC HÀNH LAB 6

COOKIE POISONING

Sinh viên: Lê Minh - MSSV: 21127645

Flask/SQLite - <http://127.0.0.1:5006> - localhost

1. Mục tiêu và môi trường thực hành

Nhận diện Cookie Poisoning và chứng minh server-side session trên localhost.

2. Kịch bản và các bước thực hiện

2.1 Quan sát cookie

Ghi cookie và flags.

ẢNH 01/09
Tên file: 01_cookie_flags.png
Tiêu đề ảnh: Quan sát cookie và các thuộc tính
Chèn ảnh tại vị trí này.
URL hoặc lệnh: `http://127.0.0.1:5006`
Thao tác: Đăng nhập user demo rồi chọn cookie đang dùng.
Panel: Application > Storage > Cookies
Phải thấy: Name, Value đã che nếu cần, Domain, Path, HttpOnly, Secure, SameSite
Kết quả: Các thuộc tính cookie local đọc được rõ ràng.
Caption: Cookie demo và các thuộc tính bảo vệ được quan sát trong DevTools.

2.2 Plain Cookie

Sửa role và quan sát cấp quyền sai.

ẢNH 02/09
Tên file: 02_plain_role_tamper.png
Tiêu đề ảnh: Plain Cookie trước và sau khi sửa role
Chèn ảnh tại vị trí này.
URL hoặc lệnh: `http://127.0.0.1:5006/vulnerable/plain`
Thao tác: Đăng nhập student, ghi trạng thái bị từ chối; sửa `role=user` thành `role=admin` và tải lại `/admin`.
Panel: Application > Cookies + trang admin
Phải thấy: giá trị trước/sau và quyền admin được cấp sai
Kết quả: Server vulnerable tin role do client sửa.
Caption: Sửa Plain Cookie làm vượt kiểm soát truy cập ở bản vulnerable.

2.3 Base64 Cookie

Decode, sửa role và encode lại.

ẢNH 03/09
Tên file: 03_base64_role_tamper.png
Tiêu đề ảnh: Base64 Cookie decode và sửa role
Chèn ảnh tại vị trí này.
URL hoặc lệnh: `http://127.0.0.1:5006/vulnerable/base64`
Thao tác: Decode JSON bằng inspector tích hợp, đổi role thành admin, encode lại và tải trang admin.
Panel: Base64 Inspector + Application > Cookies
Phải thấy: JSON gốc, JSON đã sửa và kết quả server chấp nhận
Kết quả: Base64 chỉ biểu diễn dữ liệu, không bảo vệ toàn vẹn.
Caption: Cookie Base64 bị sửa role vì không có kiểm tra toàn vẹn.

2.4 Signed hợp lệ

Cookie nguyên vẹn được xác minh.

ẢNH 04/09
Tên file: 04_signed_valid.png
Tiêu đề ảnh: Signed Cookie hợp lệ
Chèn ảnh tại vị trí này.
URL hoặc lệnh: `http://127.0.0.1:5006/secure/signed`
Thao tác: Đăng nhập và truy cập profile/admin bằng cookie nguyên vẹn.
Panel: Signature Inspector + Network
Phải thấy: trạng thái chữ ký hợp lệ và request được xử lý
Kết quả: Cookie chưa sửa được server xác minh.
Caption: Signed Cookie nguyên vẹn vượt qua bước kiểm tra chữ ký.

2.5 Signed bị sửa

Một ký tự bị sửa làm chữ ký sai.

ẢNH 05/09
Tên file: 05_signed_tampered.png
Tiêu đề ảnh: Signed Cookie bị sửa bị từ chối
Chèn ảnh tại vị trí này.
URL hoặc lệnh: http://127.0.0.1:5006/secure/signed
Thao tác: Sửa đúng một ký tự trong cookie rồi tải lại.
Panel: Application > Cookies + Signature Inspector
Phải thấy: cookie đã sửa, chữ ký không hợp lệ và response từ chối
Kết quả: Server không dùng dữ liệu đã bị sửa.
Caption: Thay đổi một ký tự làm Signed Cookie bị server từ chối.

2.6 Encrypted token

Authenticated encryption từ chối token sửa.

ẢNH 06/09
Tên file: 06_encrypted_tampered.png
Tiêu đề ảnh: Authenticated encrypted cookie bị sửa
Chèn ảnh tại vị trí này.
URL hoặc lệnh: http://127.0.0.1:5006/secure/encrypted
Thao tác: Tạo token hợp lệ, sửa một ký tự rồi gửi lại.
Panel: Encryption Inspector + Network
Phải thấy: token hợp lệ, token bị sửa và kết quả kiểm tra toàn vẹn thất bại
Kết quả: Server từ chối token bị can thiệp.
Caption: Authenticated encryption phát hiện và từ chối token bị sửa.

2.7 Server session

Role lấy từ database.

ẢNH 07/09
Tên file: 07_server_session_authz.png
Tiêu đề ảnh: Server-side Session và authorization
Chèn ảnh tại vị trí này.
URL hoặc lệnh: http://127.0.0.1:5006/secure/session
Thao tác: Đăng nhập student rồi admin; so sánh quyết định truy cập.
Panel: Server Session + Authorization Inspector
Phải thấy: cookie chỉ chứa session ID, role lấy từ database và quyết định quyền đúng
Kết quả: Student bị từ chối; admin hợp lệ được phép.
Caption: Server-side Session lấy quyền từ dữ liệu server cho từng request.

2.8 Vòng đời session

Rotation, logout và token cũ.

ẢNH 08/09
Tên file: 08_session_lifecycle.png
Tiêu đề ảnh: Rotation, logout và token cũ
Chèn ảnh tại vị trí này.
URL hoặc lệnh: http://127.0.0.1:5006/secure/session
Thao tác: Ghi session trước/sau đăng nhập, logout rồi thử lại token cũ.
Panel: Application > Cookies + Session/Audit Inspector
Phải thấy: session ID rotate, logout invalidation và token cũ bị từ chối
Kết quả: Phiên cũ không còn dùng được.
Caption: Vòng đời phiên an toàn gồm rotation và hủy server-side khi logout.

3. Nguyên nhân kỹ thuật

Root cause là tin role client-controlled. Base64 không bảo vệ toàn vẹn; signed/encrypted token vẫn cần authorization.

4. Kết quả và bằng chứng

Ảnh 01-08 đối chiếu vulnerable, kiểm tra toàn vẹn và session server-side.

5. Mức độ ảnh hưởng

Rủi ro gồm leo thang đặc quyền và truy cập trái phép; lab giới hạn dữ liệu local.

6. Bản vá và cách phòng chống

Dùng session ID ngẫu nhiên, role trong DB, authorization từng request, ký/mã hóa có xác thực, flags, rotation và logout invalidation.

Đoạn vulnerable

```
role = request.cookies.get("role")
if role == "admin":
    return admin_page()
```

Đoạn secure

```
session_id = request.cookies.get("session_id")
session = load_active_session(session_id)
user = load_user(session.user_id)
require_role(user, "admin")
```

7. Trả lời các câu hỏi báo cáo trong BaiTapTopic04.docx

Vì sao cookie là dữ liệu không đáng tin cậy?

Cookie nằm ở client, người dùng có thể đọc, xóa hoặc sửa rồi gửi lại. Server phải xác minh toàn vẹn và phân quyền bằng dữ liệu server-side.

Cookie Poisoning khác Session Hijacking như thế nào?

Poisoning sửa nội dung cookie để thay đổi quyết định; hijacking chiếm một session/token hợp lệ của người khác để mạo danh.

Base64 có phải là mã hóa không?

Không. Base64 chỉ biểu diễn byte thành văn bản và có thể decode/encode lại mà không cần khóa.

Signed cookie giải quyết vấn đề gì?

Chữ ký phát hiện sửa đổi và xác thực nguồn tạo cookie; nó không tự che nội dung và không thay thế authorization.

Vì sao server-side authorization vẫn là bắt buộc?

Ngay cả cookie hợp lệ chỉ mô tả phiên. Mỗi request vẫn phải kiểm tra danh tính, role và quyền đối với tài nguyên hiện tại ở server.

8. Kết quả kiểm thử

Pytest ghi nhận: 183 passed.

ẢNH 09/09
Tên file: 09_audit_test_report.png
Tiêu đề ảnh: Audit, kiểm thử và report artifacts
Chèn ảnh tại vị trí này.
URL hoặc lệnh: http://127.0.0.1:5006/audit-logs và Terminal Lab06
Thao tác: Ghép audit sự kiện tamper với kết quả pytest và danh sách report.
Panel: Audit Inspector + Terminal
Phải thấy: audit thật, tổng kết pytest thật và tên DOCX/PDF đã sinh
Kết quả: Các artifact phản ánh đúng lệnh vừa chạy.
Caption: Audit, kiểm thử và báo cáo của Lab06 được ghi nhận từ dữ liệu thật.

9. Kết luận

Cookie là input; toàn vẹn, authorization và vòng đời phiên tạo ranh giới tin cậy.